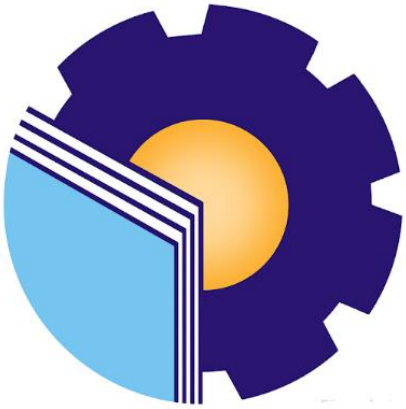
LAPORAN PRAKTIKUM

KEAMANAN PERANGKAT LUNAK

“SECURE SDLC, ATTACK SURFACE DAN THREAT MODELING”



DISUSUN OLEH:

SULESTARI (6304240033)

DOSEN PENGAMPU:

MUHAMMAD ASEP SUBANDRI, M.Kom

PROGRAM STUDI REKAYASA PERANGKAT LUNAK

JURUSAN TEKNIK INFORMATIKA

POLITEKNIK NEGERI BENGKALIS

TA 2025/2026

OUTPUT SECURE SDLC, ATTACK SURFACE DAN THREAT MODELING

CAKUPAN SISTEM

Analisis pada praktikum ini dilakukan terhadap aplikasi OWASP Juice Shop yang berjalan secara lokal di http://localhost:3000, dengan fokus pada alur login dan checkout. Aktor yang terlibat adalah pelanggan (*customer*) yang melakukan login menggunakan akun uji, memilih produk, menambahkan produk ke keranjang, mengisi alamat pengiriman, dan menyelesaikan checkout hingga pesanan berhasil dibuat. Data yang diproses meliputi data akun pengguna, informasi produk dan harga, data keranjang, serta data pesanan dan alamat pengiriman. Aset yang terkait dengan alur tersebut mengacu pada Bab 2, yaitu A-01 (data akun pengguna), A-02 (data pesanan dan alamat pengiriman), A-03 (katalog produk dan harga), A-04 (data keranjang), A-05 (layanan web), dan A-08 (container/server Juice Shop).

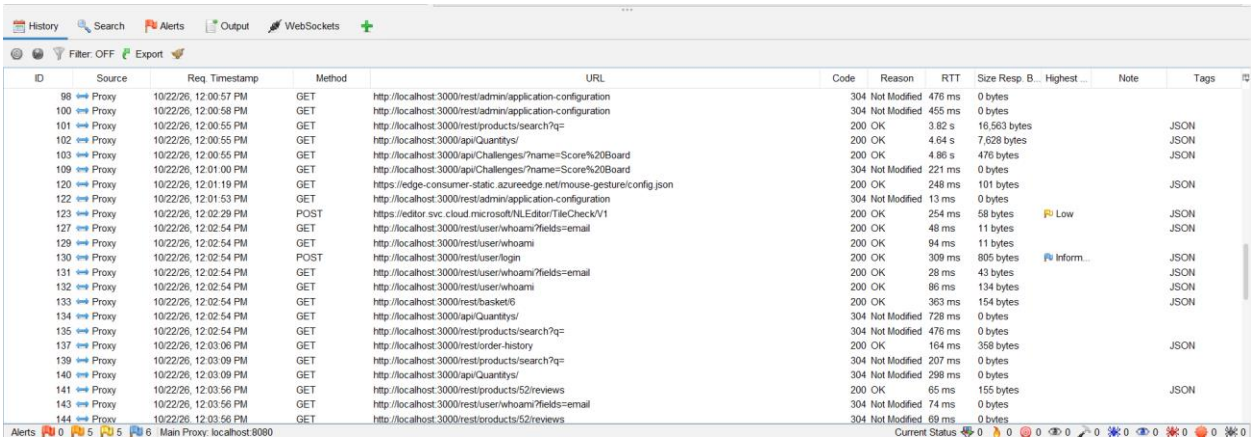
ATTACK SURFACE MAP

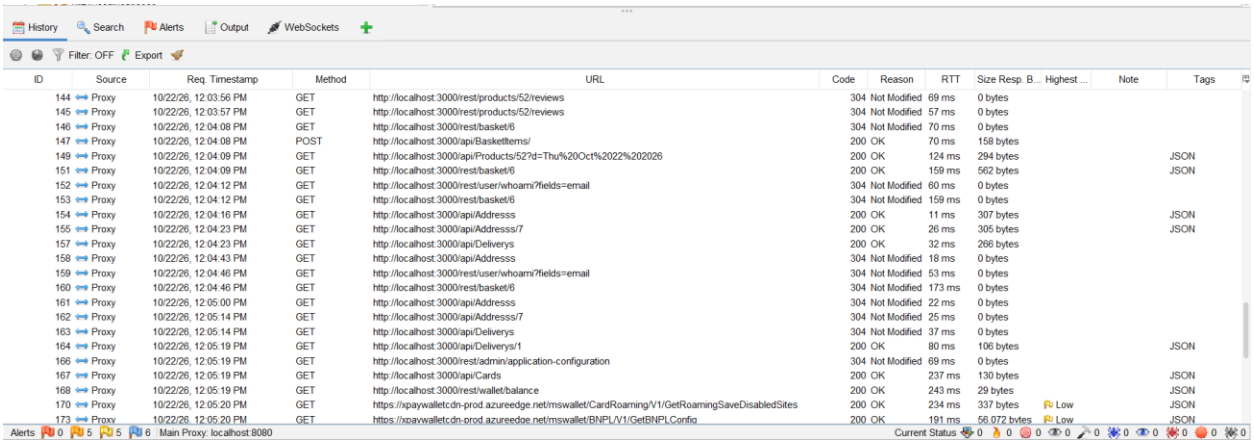
ID	Entry point (URL/form)	Metode	Data masuk	Perlu login	Catatan/bukti
AS-01	/rest/user/login	POST	email, password	Tidak	ZAP History #130, respons 200 OK.
AS-02	/rest/user/whoami?fields=email	GET	Parameter fields=email	Ya	ZAP History #127 dan #131, respons 200 OK.
AS-03	/rest/user/whoami	GET	Tidak ada parameter URL	Ya	ZAP History #129 dan #132, respons 200 OK.

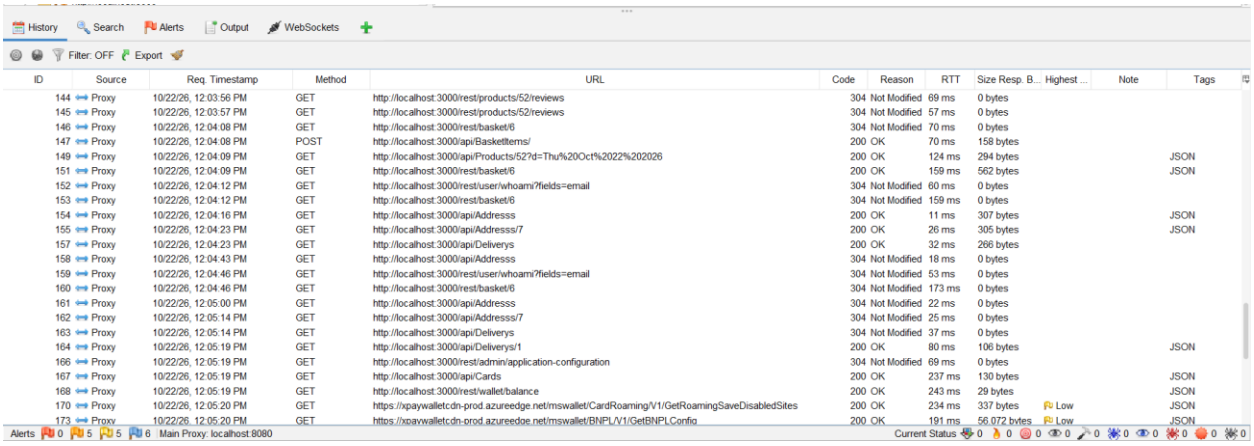
AS-04	/rest/products/search?q=	GET	Parameter pencarian q	Tidak	ZAP History #101, respons 200 OK.
AS-05	/rest/basket/6	GET	ID keranjang 6 pada URL	Ya	ZAP History #133 dan #151, respons 200 OK.
AS-06	/api/BasketItems/	POST	ProductId, BasketId, quantity	Ya	ZAP History #147, respons 200 OK. Body berisi ProductId: 52, BasketId: "6", dan quantity: 1.
AS-07	/api/Addresss	GET	Tidak ada parameter URL	Ya	ZAP History #154, respons 200 OK.
AS-08	/api/Addresss/7	GET	ID alamat 7 pada URL	Ya	ZAP History #155, respons 200 OK.
AS-09	/api/Deliverys	GET	Tidak ada parameter URL	Ya	ZAP History #157, respons 200 OK.
AS-10	/api/Deliverys/1	GET	ID metode pengiriman 1 pada URL	Ya	ZAP History #164, respons 200 OK.

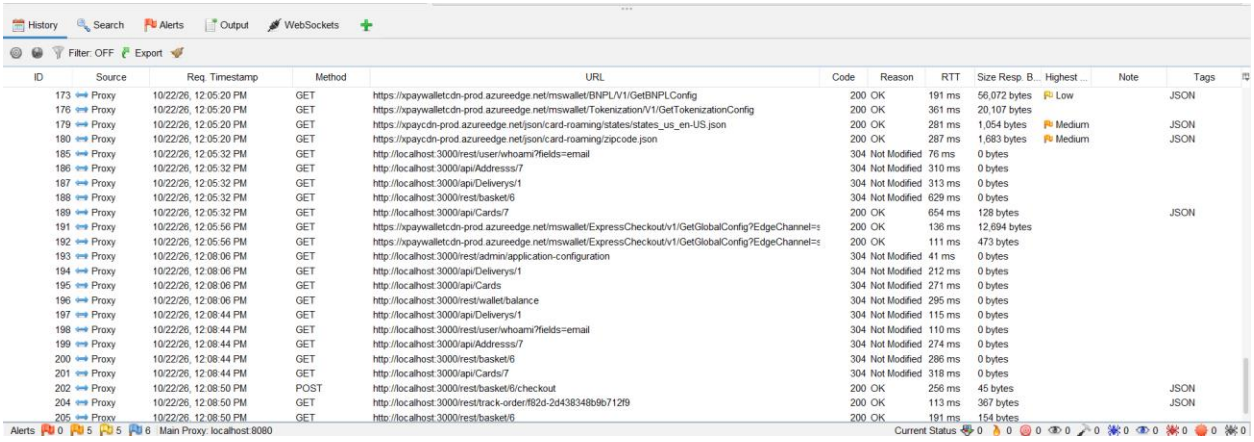
AS-11	/api/Cards	GET	Tidak ada parameter URL	Ya	ZAP History #167, respons 200 OK.
AS-12	/rest/basket/6/checkout	POST	couponData, paymentId, addressId, deliveryMethodId	Ya	ZAP History #202, respons 200 OK. Body memuat data kupon dan ID pembayaran, alamat, serta metode pengiriman.

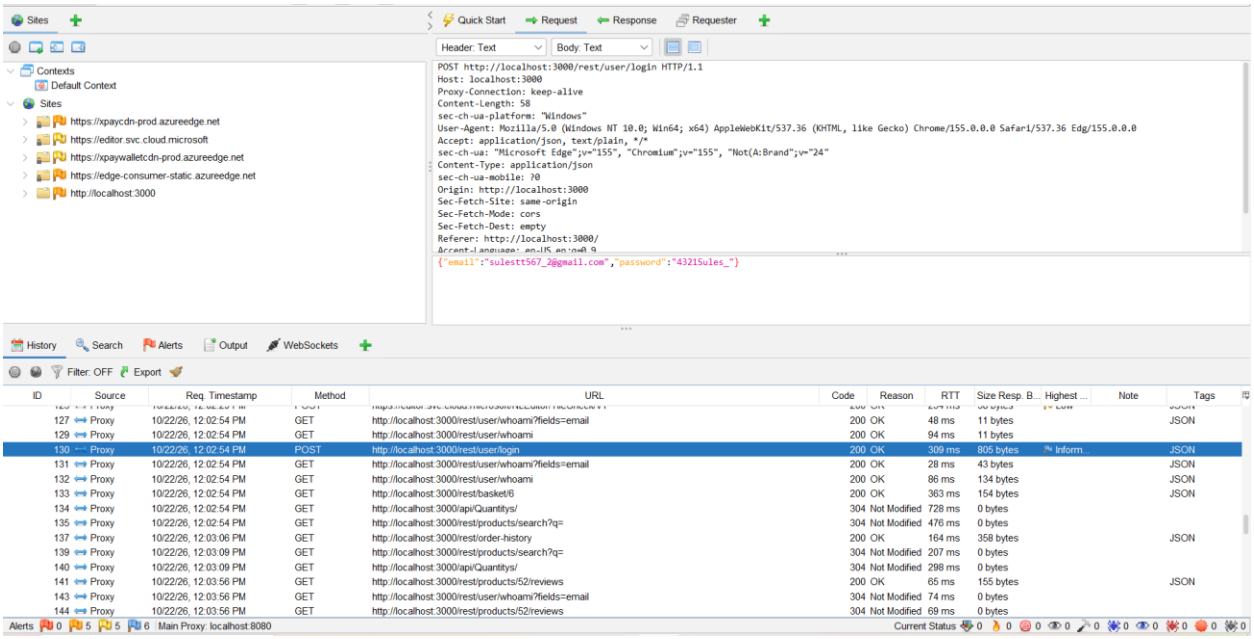
Bukti History:

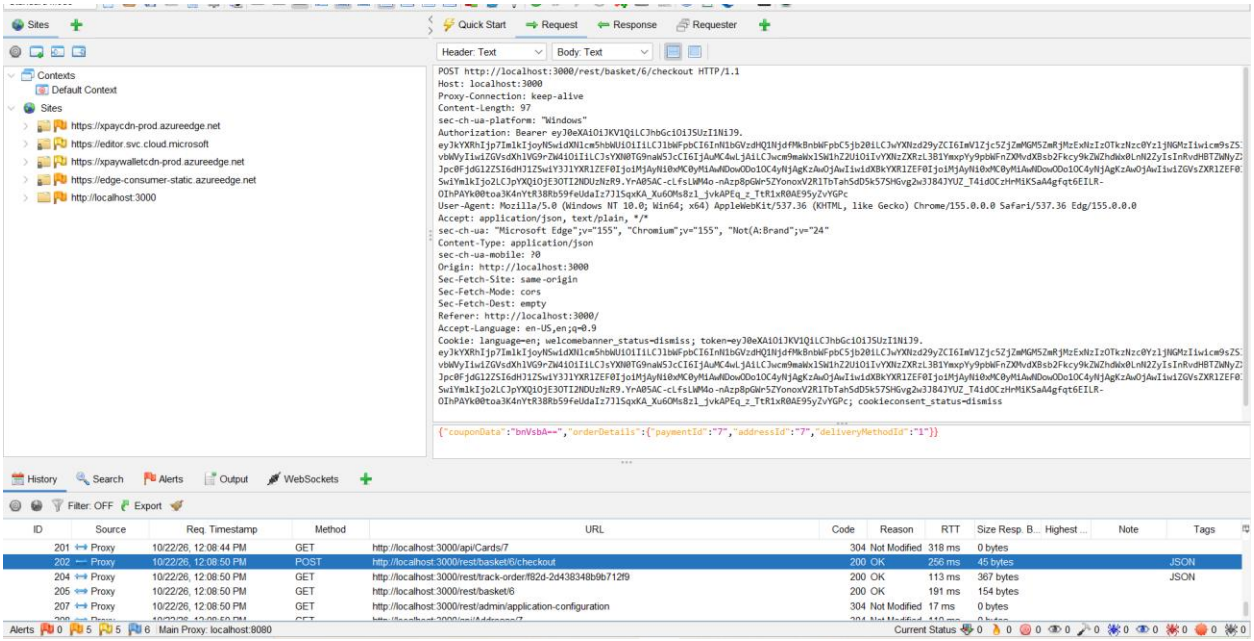



History
Search
Alerts
Output
WebSockets
Filter: OFF
Export
ID Source Req. Timestamp Method URL Code Reason RTT Size Resp. B... Highest ... Note Tags
144 Proxy 10/22/26, 12:03:56 PM GET http://localhost:3000/rest/products/52/reviews 304 Not Modified 69 ms 0 bytes
145 Proxy 10/22/26, 12:03:57 PM GET http://localhost:3000/rest/products/52/reviews 304 Not Modified 57 ms 0 bytes
146 Proxy 10/22/26, 12:04:08 PM GET http://localhost:3000/rest/basket/6 304 Not Modified 70 ms 0 bytes
147 Proxy 10/22/26, 12:04:08 PM POST http://localhost:3000/api/BasketItems/ 200 OK 70 ms 158 bytes
149 Proxy 10/22/26, 12:04:09 PM GET http://localhost:3000/api/Products/52?d=Thu%20Oct%2022%202026 200 OK 124 ms 294 bytes JSON
151 Proxy 10/22/26, 12:04:09 PM GET http://localhost:3000/rest/basket/6 200 OK 159 ms 562 bytes JSON
152 Proxy 10/22/26, 12:04:12 PM GET http://localhost:3000/rest/user/whoami?fields=email 304 Not Modified 60 ms 0 bytes
153 Proxy 10/22/26, 12:04:12 PM GET http://localhost:3000/rest/basket/6 304 Not Modified 159 ms 0 bytes
154 Proxy 10/22/26, 12:04:16 PM GET http://localhost:3000/api/Addresss 200 OK 11 ms 307 bytes JSON
155 Proxy 10/22/26, 12:04:23 PM GET http://localhost:3000/api/Addresss/7 200 OK 26 ms 305 bytes JSON
157 Proxy 10/22/26, 12:04:23 PM GET http://localhost:3000/api/Deliverys 200 OK 32 ms 266 bytes
158 Proxy 10/22/26, 12:04:43 PM GET http://localhost:3000/api/Addresss 304 Not Modified 18 ms 0 bytes
159 Proxy 10/22/26, 12:04:46 PM GET http://localhost:3000/rest/user/whoami?fields=email 304 Not Modified 53 ms 0 bytes
160 Proxy 10/22/26, 12:04:46 PM GET http://localhost:3000/rest/basket/6 304 Not Modified 173 ms 0 bytes
161 Proxy 10/22/26, 12:05:00 PM GET http://localhost:3000/api/Addresss 304 Not Modified 22 ms 0 bytes
162 Proxy 10/22/26, 12:05:14 PM GET http://localhost:3000/api/Addresss/7 304 Not Modified 25 ms 0 bytes
163 Proxy 10/22/26, 12:05:14 PM GET http://localhost:3000/api/Deliverys 304 Not Modified 37 ms 0 bytes
164 Proxy 10/22/26, 12:05:19 PM GET http://localhost:3000/api/Deliverys/1 200 OK 80 ms 106 bytes JSON
166 Proxy 10/22/26, 12:05:19 PM GET http://localhost:3000/rest/admin/application-configuration 304 Not Modified 69 ms 0 bytes
167 Proxy 10/22/26, 12:05:19 PM GET http://localhost:3000/api/Cards 200 OK 237 ms 130 bytes JSON
168 Proxy 10/22/26, 12:05:19 PM GET http://localhost:3000/rest/wallet/balance 200 OK 243 ms 29 bytes JSON
170 Proxy 10/22/26, 12:05:20 PM GET https://xpaywalletcdn-prod.azureedge.net/mswallet/CardRoaming/V1/GetRoamingSaveDisabledSites 200 OK 234 ms 337 bytes Low JSON
173 Proxy 10/22/26, 12:05:20 PM GET https://xpaywalletcdn-prod.azureedge.net/mswallet/BNPL/V1/GetBNPLConfig 200 OK 191 ms 56,072 bytes Low JSON
Alerts 0 5 5 6 Main Proxy: localhost:8080
Current Status 0 0 0 0 0 0 0 0 0 0 0


History
Search
Alerts
Output
WebSockets
Filter: OFF
Export
ID Source Req. Timestamp Method URL Code Reason RTT Size Resp. B... Highest ... Note Tags
144 Proxy 10/22/26, 12:03:56 PM GET http://localhost:3000/rest/products/52/reviews 304 Not Modified 69 ms 0 bytes
145 Proxy 10/22/26, 12:03:57 PM GET http://localhost:3000/rest/products/52/reviews 304 Not Modified 57 ms 0 bytes
146 Proxy 10/22/26, 12:04:08 PM GET http://localhost:3000/rest/basket/6 304 Not Modified 70 ms 0 bytes
147 Proxy 10/22/26, 12:04:08 PM POST http://localhost:3000/api/BasketItems/ 200 OK 70 ms 158 bytes
149 Proxy 10/22/26, 12:04:09 PM GET http://localhost:3000/api/Products/52?d=Thu%20Oct%2022%202026 200 OK 124 ms 294 bytes JSON
151 Proxy 10/22/26, 12:04:09 PM GET http://localhost:3000/rest/basket/6 200 OK 159 ms 562 bytes JSON
152 Proxy 10/22/26, 12:04:12 PM GET http://localhost:3000/rest/user/whoami?fields=email 304 Not Modified 60 ms 0 bytes
153 Proxy 10/22/26, 12:04:12 PM GET http://localhost:3000/rest/basket/6 304 Not Modified 159 ms 0 bytes
154 Proxy 10/22/26, 12:04:16 PM GET http://localhost:3000/api/Addresss 200 OK 11 ms 307 bytes JSON
155 Proxy 10/22/26, 12:04:23 PM GET http://localhost:3000/api/Addresss/7 200 OK 26 ms 305 bytes JSON
157 Proxy 10/22/26, 12:04:23 PM GET http://localhost:3000/api/Deliverys 200 OK 32 ms 266 bytes
158 Proxy 10/22/26, 12:04:43 PM GET http://localhost:3000/api/Addresss 304 Not Modified 18 ms 0 bytes
159 Proxy 10/22/26, 12:04:46 PM GET http://localhost:3000/rest/user/whoami?fields=email 304 Not Modified 53 ms 0 bytes
160 Proxy 10/22/26, 12:04:46 PM GET http://localhost:3000/rest/basket/6 304 Not Modified 173 ms 0 bytes
161 Proxy 10/22/26, 12:05:00 PM GET http://localhost:3000/api/Addresss 304 Not Modified 22 ms 0 bytes
162 Proxy 10/22/26, 12:05:14 PM GET http://localhost:3000/api/Addresss/7 304 Not Modified 25 ms 0 bytes
163 Proxy 10/22/26, 12:05:14 PM GET http://localhost:3000/api/Deliverys 304 Not Modified 37 ms 0 bytes
164 Proxy 10/22/26, 12:05:19 PM GET http://localhost:3000/api/Deliverys/1 200 OK 80 ms 106 bytes JSON
166 Proxy 10/22/26, 12:05:19 PM GET http://localhost:3000/rest/admin/application-configuration 304 Not Modified 69 ms 0 bytes
167 Proxy 10/22/26, 12:05:19 PM GET http://localhost:3000/api/Cards 200 OK 237 ms 130 bytes JSON
168 Proxy 10/22/26, 12:05:19 PM GET http://localhost:3000/rest/wallet/balance 200 OK 243 ms 29 bytes JSON
170 Proxy 10/22/26, 12:05:20 PM GET https://xpaywalletcdn-prod.azureedge.net/mswallet/CardRoaming/V1/GetRoamingSaveDisabledSites 200 OK 234 ms 337 bytes Low JSON
173 Proxy 10/22/26, 12:05:20 PM GET https://xpaywalletcdn-prod.azureedge.net/mswallet/BNPL/V1/GetBNPLConfig 200 OK 191 ms 56,072 bytes Low JSON
Alerts 0 5 5 6 Main Proxy: localhost:8080
Current Status 0 0 0 0 0 0 0 0 0 0 0


History
Search
Alerts
Output
WebSockets
Filter: OFF
Export
ID Source Req. Timestamp Method URL Code Reason RTT Size Resp. B... Highest ... Note Tags
173 Proxy 10/22/26, 12:05:20 PM GET https://xpaywalletcdn-prod.azureedge.net/mswallet/BNPL/V1/GetBNPLConfig 200 OK 191 ms 56,072 bytes Low JSON
176 Proxy 10/22/26, 12:05:20 PM GET https://xpaywalletcdn-prod.azureedge.net/mswallet/Tokenization/V1/GetTokenizationConfig 200 OK 361 ms 20,107 bytes
179 Proxy 10/22/26, 12:05:20 PM GET https://xpaycdn-prod.azureedge.net/json/card-roaming/states/states_us_en-US.json 200 OK 281 ms 1,054 bytes Medium JSON
180 Proxy 10/22/26, 12:05:20 PM GET https://xpaycdn-prod.azureedge.net/json/card-roaming/zipcode.json 200 OK 287 ms 1,683 bytes Medium JSON
185 Proxy 10/22/26, 12:05:32 PM GET http://localhost:3000/rest/user/whoami?fields=email 304 Not Modified 76 ms 0 bytes
186 Proxy 10/22/26, 12:05:32 PM GET http://localhost:3000/api/Addresss/7 304 Not Modified 310 ms 0 bytes
187 Proxy 10/22/26, 12:05:32 PM GET http://localhost:3000/api/Deliverys/1 304 Not Modified 313 ms 0 bytes
188 Proxy 10/22/26, 12:05:32 PM GET http://localhost:3000/rest/basket/6 304 Not Modified 629 ms 0 bytes
189 Proxy 10/22/26, 12:05:32 PM GET http://localhost:3000/api/Cards/7 200 OK 654 ms 128 bytes JSON
191 Proxy 10/22/26, 12:05:56 PM GET https://xpaywalletcdn-prod.azureedge.net/mswallet/ExpressCheckout/v1/GetGlobalConfig?EdgeChannel=s 200 OK 136 ms 12,694 bytes
192 Proxy 10/22/26, 12:05:56 PM GET https://xpaywalletcdn-prod.azureedge.net/mswallet/ExpressCheckout/v1/GetGlobalConfig?EdgeChannel=s 200 OK 111 ms 473 bytes
193 Proxy 10/22/26, 12:08:06 PM GET http://localhost:3000/rest/admin/application-configuration 304 Not Modified 41 ms 0 bytes
194 Proxy 10/22/26, 12:08:06 PM GET http://localhost:3000/api/Deliverys/1 304 Not Modified 212 ms 0 bytes
195 Proxy 10/22/26, 12:08:06 PM GET http://localhost:3000/api/Cards 304 Not Modified 271 ms 0 bytes
196 Proxy 10/22/26, 12:08:06 PM GET http://localhost:3000/rest/wallet/balance 304 Not Modified 295 ms 0 bytes
197 Proxy 10/22/26, 12:08:44 PM GET http://localhost:3000/api/Deliverys/1 304 Not Modified 115 ms 0 bytes
198 Proxy 10/22/26, 12:08:44 PM GET http://localhost:3000/rest/user/whoami?fields=email 304 Not Modified 110 ms 0 bytes
199 Proxy 10/22/26, 12:08:44 PM GET http://localhost:3000/api/Addresss/7 304 Not Modified 274 ms 0 bytes
200 Proxy 10/22/26, 12:08:44 PM GET http://localhost:3000/rest/basket/6 304 Not Modified 286 ms 0 bytes
201 Proxy 10/22/26, 12:08:44 PM GET http://localhost:3000/api/Cards/7 304 Not Modified 318 ms 0 bytes
202 Proxy 10/22/26, 12:08:50 PM POST http://localhost:3000/rest/basket/6/checkout 200 OK 256 ms 45 bytes JSON
204 Proxy 10/22/26, 12:08:50 PM GET http://localhost:3000/rest/track-order/f82d-2d438348b9b712f9 200 OK 113 ms 367 bytes JSON
205 Proxy 10/22/26, 12:08:50 PM GET http://localhost:3000/rest/basket/6 200 OK 191 ms 154 bytes
Alerts 0 5 5 6 Main Proxy: localhost:8080
Current Status 0 0 0 0 0 0 0 0 0 0 0

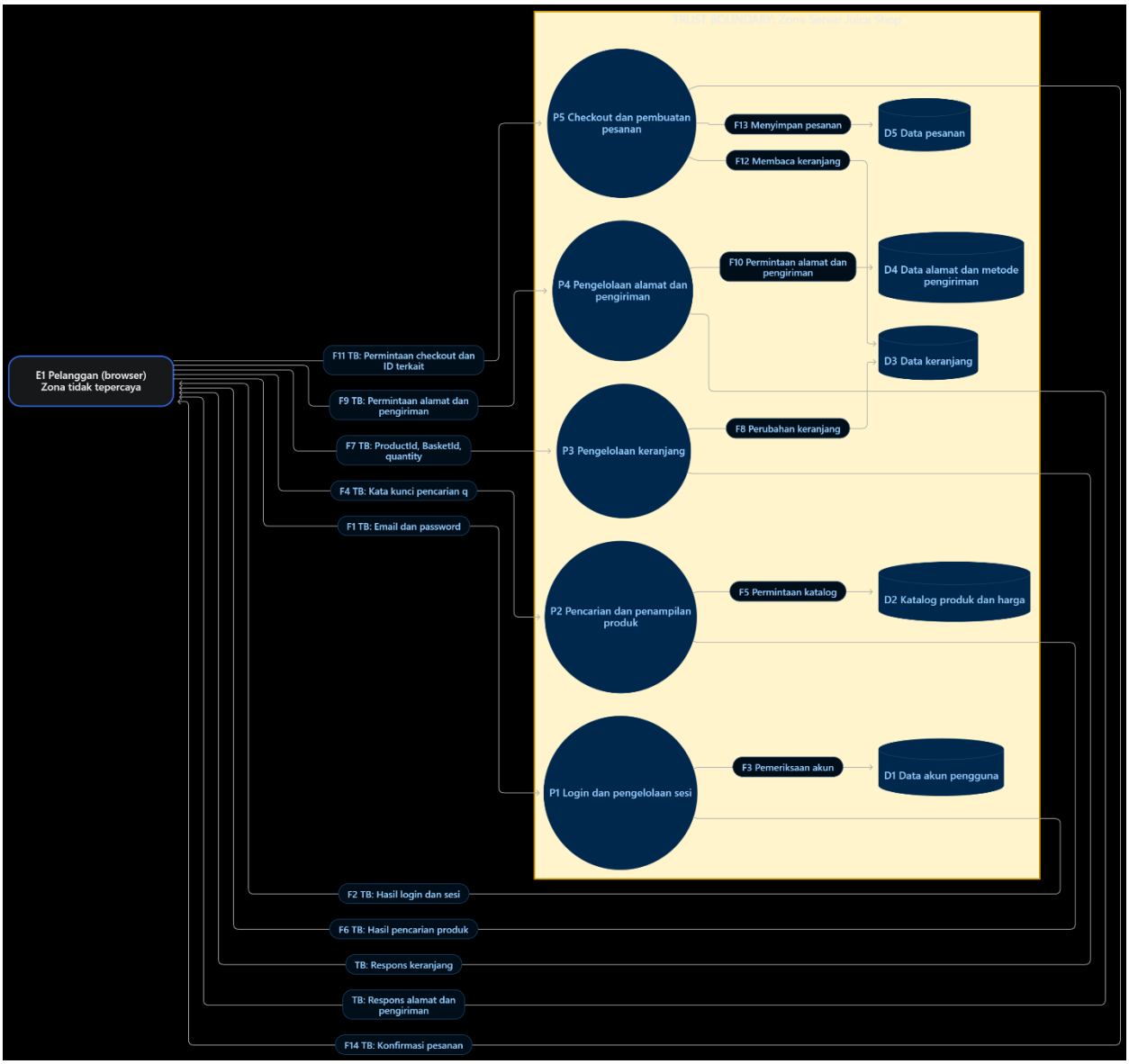




DFD

ID	Tipe	Nama elemen	Trust zone
E1	External entity	Pelanggan (browser)	Tidak tepercaya

P1	Process	Login dan pengelolaan sesi	Server
P2	Process	Pencarian dan penampilan produk	Server
P3	Process	Pengelolaan keranjang	Server
P4	Process	Pengelolaan alamat dan metode pengiriman	Server
P5	Process	Checkout dan pembuatan pesanan	Server
D1	Data store	Data akun pengguna	Server
D2	Data store	Data katalog produk dan harga	Server
D3	Data store	Data keranjang	Server
D4	Data store	Data alamat dan metode pengiriman	Server
D5	Data store	Data pesanan	Server



THREAT MODEL

ID	Elemen DFD	STRIDE	Threat konkret	Aset / R-xx	L	I	Skor	Respons dan mitigasi
TM-01	P1 (F1)	S	Penyerang mencoba banyak kombinasi password untuk	A-01 / R-01	4	4	16 Kritis	Mitigate: terapkan rate limiting, pembatasan

			menyamar sebagai pelanggan melalui proses login.					percobaan login, dan MFA bila sesuai.
TM-02	P1 (F1)	S	Penyerang menggunakan kredensial yang dicuri atau password lemah untuk mengambil alih akun pelanggan.	A-01 / R-02	4	4	16 Kritis	Mitigate: terapkan kebijakan password kuat, pemeriksaan password yang pernah bocor, dan perlindungan login.
TM-03	P5 (F11)	T	Pelanggan yang berniat jahat mengubah ID alamat atau informasi pesanan pada request checkout untuk memanipulasi pesanan.	A-02 / R-06	3	5	15 Kritis	Mitigate: validasi kepemilikan pesanan dan alamat di sisi server serta periksa otorisasi setiap objek.
TM-04	P2 (F4)	T	Penyerang memanipulasi parameter atau request produk untuk mencoba mengubah data katalog atau harga tanpa izin.	A-03 / —	2	4	8 Sedang	Mitigate: validasi input dan batasi operasi perubahan katalog hanya untuk peran yang berwenang.
TM-05	P5 (F13)	R	Pengguna menyangkal telah membuat pesanan karena sistem tidak menyimpan bukti	A-02, A-10 / —	2	3	6 Sedang	Mitigate: simpan riwayat pesanan, waktu transaksi, ID transaksi, dan log

			transaksi dan riwayat aktivitas yang memadai.					aktivitas yang terlindungi.
TM-06	P1 (F2)	I	Penyerang memperoleh informasi akun atau sesi pelanggan melalui penanganan autentikasi yang tidak aman.	A-01 / R-03, R-05, R-08	3	4	12 Tinggi	Mitigate: lindungi token dan cookie sesi, gunakan HTTPS pada penerapan nyata, serta hindari membocorkan informasi sensitif dalam respons.
TM-07	D1 (data akun)	I	Pihak yang tidak berwenang memperoleh data akun pelanggan yang tersimpan atau terekspos melalui aplikasi.	A-01, A-07 / R-07	3	4	12 Tinggi	Mitigate: batasi akses data, jangan menyimpan password dalam bentuk teks biasa, dan hindari menaruh rahasia pada kode sisi klien.
TM-08	P2 (F4)	D	Penyerang mengirim permintaan pencarian produk secara berlebihan sehingga sumber daya server terkuras dan layanan melambat.	A-05, A-08 / —	3	4	12 Tinggi	Mitigate: terapkan rate limiting, pembatasan penggunaan sumber daya, dan pemantauan permintaan berulang.
TM-09	P1 (proses autentikasi)	E	Pengguna dengan hak akses pelanggan mencoba mengakses	A-06, A-09	3	5	15 Kritis	Mitigate: lakukan pemeriksaan otorisasi di sisi

			fungsi administrator tanpa otorisasi yang sesuai.	/ R-07*				server, terapkan prinsip least privilege, dan uji pembatasan akses berdasarkan peran.
TM-10	P3 (F7)	T	Pengguna memanipulasi ProductId, BasketId, atau quantity pada request keranjang untuk mengubah isi keranjang secara tidak semestinya.	A-04 / —	3	3	9 Tinggi	Mitigate: validasi ID dan jumlah produk di server serta pastikan pengguna hanya dapat mengubah keranjangnya sendiri.
TM-11	P1 (F2)	S	Penyerang menggunakan token sesi milik pengguna lain untuk menyamar sebagai pengguna tersebut.	A-01, A-09 / R-05, R-08	3	4	12 Tinggi	Mitigate: lindungi token, gunakan cookie dengan atribut keamanan yang tepat, dan invalidasi sesi saat logout.
TM-12	P4 (F9)	I	Pengguna yang tidak berwenang mencoba membaca alamat pengiriman atau informasi pesanan milik pelanggan lain.	A-02 / R-06	3	5	15 Kritis	Mitigate: periksa kepemilikan data pada setiap permintaan dan jangan hanya mengandalkan ID objek pada URL.

MENILAI RISK DAN MENENTUKAN RESPONS

Penilaian berikut merupakan estimasi risiko awal berdasarkan threat model, aset, dan risk register Bab 2, bukan bukti bahwa serangan tersebut telah terjadi.

ID	Threat	L	Alasan L	I	Alasan I	L × I	Kategori	Respons dan kontrol yang diusulkan
TM-01	Percobaan banyak password pada login	4	Serangan otomatis relatif mudah dilakukan jika pembatasan tidak memadai.	4	Pengambilalihan akun dapat mengekspos data pengguna.	16	Kritis	Mitigate: rate limiting, pembatasan percobaan login, dan MFA.
TM-02	Penggunaan kredensial curian atau password lemah	4	Kredensial dapat diperoleh melalui kebocoran atau penggunaan ulang password.	4	Akun pelanggan dapat diambil alih.	16	Kritis	Mitigate: kebijakan password kuat, pemeriksaan password bocor, dan perlindungan login.
TM-03	Manipulasi alamat atau data pesanan saat checkout	3	Memerlukan manipulasi request dan keberhasilan melewati pemeriksaan otorisasi.	5	Dapat memengaruhi kerahasiaan atau integritas data pesanan.	15	Kritis	Mitigate: validasi kepemilikan objek dan otorisasi di sisi server.
TM-09	Pelanggan mencoba	3	Keberhasilan bergantung	5	Akses administrator	15	Kritis	Mitigate: pemeriksaan

	mengakses fungsi administrator		pada kelemahan pemeriksaan hak akses.		yang tidak sah dapat berdampak besar pada aplikasi.			otorisasi server, prinsip least privilege, dan pengujian akses berbasis peran.
TM-12	Akses tidak sah terhadap alamat pengiriman pengguna lain	3	Memerlukan keberhasilan melewati pemeriksaan akses data.	5	Alamat dan informasi pesanan merupakan data sensitif.	15	Kritis	Mitigate: validasi kepemilikan data pada setiap request dan pembatasan akses objek.
TM-06	Pengungkapan informasi akun atau sesi	3	Dapat terjadi apabila penanganan sesi atau respons aplikasi tidak aman.	4	Informasi yang terekspos dapat membantu pengambilalihan akun.	12	Tinggi	Mitigate: lindungi token dan cookie, gunakan HTTPS pada penerapan nyata, serta minimalkan informasi sensitif

								dalam respons.
TM-07	Pengungkapan data akun yang tersimpan	3	Bergantung pada adanya jalur akses tidak sah atau kebocoran data.	4	Data akun yang bocor dapat merugikan pengguna.	12	Tinggi	Mitigate: batasi akses data, lindungi password, dan hindari rahasia pada kode sisi klien.
TM-08	Permintaan pencarian berlebihan hingga layanan melambat	3	Permintaan otomatis dapat membebani sumber daya server.	4	Layanan yang lambat atau tidak tersedia mengganggu pengguna.	12	Tinggi	Mitigate: rate limiting, pembatasan sumber daya, dan pemantauan trafik.
TM-11	Penggunaan token sesi milik pengguna lain	3	Memerlukan token yang berhasil diperoleh atau disalahgunakan.	4	Penyerang dapat bertindak sebagai pengguna yang sah.	12	Tinggi	Mitigate: lindungi token, gunakan atribut cookie yang tepat, dan invalidasi sesi saat logout.

TM-10	Manipulasi data keranjang	3	Pengguna dapat mengubah parameter request, tetapi dampaknya bergantung pada validasi server.	3	Isi keranjang dapat berubah secara tidak semestinya.	9	Sedang	Mitigate: validasi produk, jumlah, dan kepemilikan keranjang di server.
TM-04	Manipulasi katalog atau harga produk	2	Memerlukan kelemahan otorisasi atau validasi pada operasi perubahan data.	4	Perubahan harga dapat memengaruhi integritas transaksi.	8	Sedang	Mitigate: validasi input dan batasi perubahan katalog untuk peran berwenang.
TM-05	Pengguna menyangkal transaksi karena bukti tidak memadai	2	Risiko bergantung pada kelengkapan pencatatan transaksi.	3	Sengketa transaksi akan lebih sulit ditelusuri.	6	Sedang	Mitigate: catat ID transaksi, waktu, dan riwayat aktivitas dalam log yang terlindungi.

Ringkasan prioritas risiko

Kritis — 4 threat

TM-01, TM-02, TM-03, TM-09, dan TM-12 sebenarnya berjumlah 5 threat.

Tinggi — 4 threat

TM-06, TM-07, TM-08, TM-11.

Sedang — 3 threat

TM-04, TM-05, TM-10.

Jumlahnya adalah 12 threat. Semua threat di atas memilih respons mitigate, yaitu mengurangi kemungkinan terjadinya ancaman atau dampaknya melalui kontrol keamanan. Pilihan ini merupakan usulan awal, bukan satu-satunya respons yang mungkin; accept, transfer, atau avoid bisa dipilih jika sesuai dengan konteks dan keputusan pemilik risiko.

REFLEKSI

Threat modeling pada fase desain membantu mengidentifikasi aset penting, jalur aliran data, batas kepercayaan, dan kemungkinan ancaman sebelum aplikasi selesai dibuat. Pada tahap ini, kelemahan dalam rancangan autentikasi, otorisasi, validasi input, dan perlindungan data dapat ditemukan sebelum membutuhkan perubahan kode yang besar. Threat modeling juga membantu menentukan kontrol keamanan yang perlu dirancang sejak awal berdasarkan tingkat risiko. Jika baru dilakukan setelah kode selesai, perbaikan bisa menjadi lebih sulit karena arsitektur dan implementasi sudah terlanjur dibuat.